Monthly Intelligence Dispatch

May 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB uncovered a series of multi-stage phishing attacks on top managers of more than 150 companies in the USA, Canada, Germany, Great Britain, the Netherlands, Hong Kong, and Singapore.
- Fresenius Group, Europe's largest private hospital operator, was reportedly affected by Snake ransomware, while in the UK two contractors, Interserve and Bam Construct, which helped build NHS Nightingale hospitals, were attacked.
- Group-IB experts detected an email campaign delivering More_eggs JS backdoor. This tool is known to have been used by the criminal groups Cobalt and Fin6.
- Group-IB helped take down around 250 phishing resources masqueraded as popular delivery services.
- Group-IB specialists discovered a new Android banking Trojan named "Alien bot", which was sold privately on underground forums.
- In early 2020, a new service for developing web fakes for the Android banking Trojans Cerberus and Anubis appeared on the underground forum Exploit.in.

PerSwaysion

Group-IB has uncovered a series of multi-stage phishing attacks on top managers of more than 150 companies in the USA, Canada, Germany, Great Britain, the Netherlands, Hong Kong, and Singapore. The campaign, named PerSwaysion after the service MS Sway that is actively used at one of the attack stages, has been active since mid-2019. Cybercriminals primarily target financial services companies, law firms, and real estate companies. Having gained access to mailboxes belonging to senior managers, attackers launch a new round of phishing attacks against the victim's contact persons. Group-IB has created a website where everyone can check whether their mailbox was compromised during the PerSwaysion campaign. Attackers have gained access to many corporate email accounts and large arrays of business correspondence, which opens up a range of opportunities for them. They can sell account access to other cybercriminals for subsequent financial fraud. Confidential business data extracted from emails can also be sold on underground resources.

Interserve	In early May, the UK's National Cybersecurity Center reported an increase in targeted attacks on British universities and research institutions working on Covid-19 research. Those behind the activity were thought to include China, Russia and Iran. However, there were no successful attack attempts. Immediately after this warning was issued, Bam Construct and Interserve, two British construction firms that helped build NHS Nightingale hospitals, were hit by cyberattacks.
Remcos RAT	Microsoft researchers discovered several malicious spam campaigns using Covid-19 as a lure to install the Remcos remote access Trojan on victims' devices. Microsoft said the attackers were targeting companies across different industries, in multiple countries across the globe. Among the victims were small businesses in the United States and manufacturing companies in South Korea.
Agent Tesla	Researchers discovered a campaign attempting to deliver malware to medical device suppliers via email. The messages state that the sender is interested in bulk purchasing pharmaceutical and medical equipment. The email contains a Word document which attempts to exploit a flaw in the Office Equation Editor, resulting in Agent Tesla being installed on the target machine.

TrickBot	Researchers uncovered a new campaign that targeted email recipients with messages purporting to be from the U.S. Department of Labor (DoL). The spam leveraged the Family and Medical Leave Act (FMLA). The messages, which were allegedly being sent out due to the pandemic, contained a DocuSign-type attachment with malicious macros. The final payload used in the recent attacks was the TrickBot Trojan.
Lokibot	A new Lokibot campaign also exploited COVID-19 to target businesses. The emails were used to deliver Lokibot malware claimed to be from the Centre for Disease Control (CDC) at the World Health Organization. The email attachment pretended to offer important advice about COVID-19 infection control and give recommendations.
Warzone RAT	IBM researchers observed a low-quality spam campaign attempting to spread Ave Maria malware, also known as Warzone RAT, via emails with malicious attachments referencing a COVID-19 SMS template. The malware only runs on Windows 7.

DMG

Group-IB helped take down about 250 phishing resources masqueraded as popular delivery services. This scheme was first discovered by CERT-GIB (Group-IB's CERT) specialists in August 2019 after receiving complaints from victims. However, the peak of activity was in the spring of 2020 during lockdown. Over the past six months, the number of newly registered phishing domains impersonating delivery service brands has grown seven-fold. The scope of this criminal technique is huge, and it is constantly being scaled. For example, one of the major criminal groups, calling itself Dreamer Money Gang (DMG), is hiring new members through a telegram bot with a promise they will be trained, gain access to "the best domains on the market", and make money quickly without any hidden interest to be paid. The daily turnover of DMG exceeds 3,000 U.S. dollars. It is interesting to note that earnings of another similar criminal group have grown rapidly in recent months: $11,500 (January 2020), $51,000 (February 2020), $90,000 (March 2020), $129,000 (April 2020).

Cobalt

Group-IB experts uncovered an email campaign delivering the More_eggs JavaScript backdoor. This tool is used by the criminal groups Cobalt and Fin6. A ZIP archive named “5sun_New_schedule.zip” that was spread during the campaign was found on May 4, 2020, after the file was uploaded to VirusTotal. More_eggs executes the following commands: download and run an executable file; execute commands in the command line interpreter, run its copies, delete its copies from the infected system, and update itself. An analysis revealed various versions of LNK files. The domain time.absolutededs.com involved in the campaign is hosted by NETERRA. The group Cobalt used the same hosting provider to carry out attacks in October 2019. The domain name e-fax.org was previously observed in the attacks involving More_Eggs in November 2019.

The top 10 tools that were used by cybercriminals in email campaigns detected by CERT-GIB in H2 2019 include the Troldesh ransomware (55%); the backdoors Pony (11%), Formbook (5%), Nanocore (4%) and Netwire (1%); the banking Trojans RTM (6%) and Emotet (5%); and the spyware AgentTesla (3%), Hawkeye (2%), and Azorult (1%). AgentTesla, Netwire and Azorult are new threats. In general, ransomware remained the most common tool delivered by malicious emails in 2019 and amounted to 47%.

In total, in 2019 CERT-GIB blocked more than 14,000 phishing resources, which is three times as many as last year (4,494). Such a sharp increase in the number of take-downs can be explained by both the effective detection of criminal schemes and a change in the phishers' tactics. The latter fact resulted in an increase in the duration of phishing attacks: in previous years, criminals mostly stopped their campaigns and quickly switched their focus to other brands after fraudulent web resources were blocked. Today they continue their activities by creating more and more pages to replace the blocked ones.

According to CERT-GIB's data, in 2019 attackers reviewed the "pool" of their victims. Phishing pages primarily targeted online services (29.3%), cloud storage services (25.4%), and financial institutions (17.6%). The statistics show that the amount of phishing resources targeting cloud storage services has almost doubled, while the number of fraudulent pages targeting users of internet service providers has tripled.

Major events: ransomware

Snake Ransomware	Fresenius, Europe's largest private hospital operator, has reportedly been hit by Snake Ransomware, affecting the company's operations throughout the world. Fresenius confirmed that its IT team 'detected a computer virus on company computers' but declined to provide further details of the incident.
Dharma	Dharma ransomware also used COVID-19 as a theme for malicious email campaigns. The attackers gained access to the target's environment via RDP and lay dormant for two days until April 10th, 2020, a public holiday. The compromised RDP server wrote numerous files over the SMB protocol, appending them with a file extension featuring the string 'cov2020'– a potential reference to the current pandemic.
Android SLocker	Bitdefender researchers discovered a fake coronavirus information app called "Koronavirus haqida," in Uzbek "About Coronavirus," which is distributed through unofficial app stores. After the user installs the application (i.e. malware SLocker) and runs it, the screen is locked and displays a simple ransomware message, in the Uzbek language. The malware remains persistent after the system reboots. In the past few months, the malware was reported in Ukraine, Russia, numerous countries in Central Asia, including Kazakhstan and Turkmenistan, and parts of India and North Africa.

Alien bot

Group-IB specialists discovered a new Android banking Trojan "Alien bot", which is sold privately on underground forums. The estimated start date for sales is January 2020. Alien bot is sold on the underground forums XSS and Exploit. The malware developer is a user with the nickname "-ringo-". The Trojan can be purchased privately by contacting its developer or technical support team. In May 2020, Group-IB analysts contacted the support team and received from them a detailed description of Alien bot. The Trojan works on all current versions of Android (5-10) and has the following features: send and intercept text messages covertly, send USSD requests, steal emails, bank card data, passwords, saved messages, address book, and a list of installed applications, intercept and redirect calls (including WhatsApp), gain remote access to the device (by installing TeamViewer covertly). Alien bot support team says that the malware was written from scratch. The bot contains 177 ready-made Android web injects. Other web injects can be added upon request. Among the list of web injects are banking applications belonging to the following countries: Australia, the United Kingdom, Germany, Israel, India, Italy, Canada, the USA, and the Netherlands.

Cerberus and Anubis

In early 2020, a new service for developing banking web fakes for Android banking Trojans Cerberus and Anubis appeared on the underground forum Exploit.in. The service was offered by a user with the nickname "InTheBox". According to the ad, the seller offered ready-made web fakes for rent and the development of web fakes for applications from GooglePlay upon request. Renting a web fake cost $10 per month, but later the author said he would only sell web fakes. The cost of one web fake was $50, then the seller reduced the price to $30. In early April, the service owner said that they began developing web fakes for the banking Trojan Alien. The author provided links to a demo video for some web fakes. In a month, 30 web fakes were developed.

Arrests and sentences

PentaGuard

Romanian authorities said they had arrested a cybercriminal group that planned to conduct ransomware attacks on hospitals in the country. The group dubbed PentaGuard intended to pose as government officials and send malicious emails with ransomware that purported to contain information on COVID-19. The hackers sought to use ransomware related to Locky or Bad Rabbit.

Forecasts and warnings

- Cybercriminals behind the PerSwaysion campaign have gained access to multiple corporate email accounts and large arrays of business correspondence, which opens up a number of opportunities for them. The attackers can sell account access to other cybercriminals for subsequent financial fraud. Confidential business data extracted from emails may be sold on underground resources.
- The success of last year's large-scale ransomware attacks on companies, corporations and even municipalities has motivated more and more threat actors to join the game. One of these new players is ProLock ransomware.
- Several posts about the immorality of attacks on medical facilities during the pandemic appeared on hacker forums, however the number of attacks on the health care system, including those using ransomware, is expected to increase.
- The second wave of COVID-19 may cause another growth in malicious campaigns exploiting the hot topic, and is likely to lead to the emergence of new fraud tactics.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159-3798
+7 495 984 33 64
intelligence@group-ib.com